

MÉTRICAS Y AUDITORÍA

BY NOVA TECH SOLUTIONS

1. OBJETIVO DE LA MEDICIÓN Y AUDITORÍA

El objetivo principal de este documento es establecer el marco formal para evaluar y cuantificar la eficacia de los controles implementados en el Sistema de Gestión de Seguridad de la Información (SGSI) de NovaTech Solutions. Como parte fundamental de la fase de Verificación (Check) del ciclo PDCA, este programa de medición y auditoría busca garantizar la protección de nuestros activos críticos, asegurar la resiliencia operativa y certificar el cumplimiento estricto del marco legal aplicable, particularmente la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP).

2. INDICADORES CLAVE DE RENDIMIENTO (KPIs) DE SEGURIDAD

Para medir de manera objetiva el rendimiento del SGSI y la adherencia a las políticas de seguridad (como el Control de Accesos, Continuidad del Negocio y Respuesta a Incidentes), se definen los siguientes Indicadores Clave de Rendimiento. Estos KPIs proporcionan visibilidad directa sobre la postura de seguridad de la organización:

Métrica / KPI	Objetivo (Meta)	Frecuencia de Medición	Responsable
Porcentaje de empleados con Autenticación Multifactor (MFA) activa	100% en accesos a Git, CRM, VPN y Cloud	Mensual	Área de Infraestructura y TI
Tiempo Medio de Detección (MTTD) ante incidentes	< 15 minutos tras la alerta inicial	Mensual	Equipo de Respuesta a Incidentes (CSIRT)
Tiempo Medio de Respuesta y Recuperación (MTTR) ante incidentes	< 4 horas (para prevenir escenarios críticos de indisponibilidad)	Mensual / Por evento	Equipo de Respuesta a Incidentes (CSIRT)

Porcentaje de éxito en pruebas de restauración de copias de seguridad (Backups)	100% de integridad y funcionalidad de los datos	Trimestral	Área de Infraestructura y TI
Número de incidentes de seguridad relacionados con fugas de datos personales	0 (Cero incidentes / Cumplimiento LFPDPPP)	Semestral	Oficial de Seguridad (CISO)

3. PROGRAMA DE AUDITORÍA INTERNA

Para asegurar que los controles de seguridad no solo se implementen, sino que operen de manera efectiva, NovaTech Solutions establece un programa estructurado de auditorías internas basado en las directrices de ISO/IEC 27001:

- **Frecuencia:** Las auditorías operativas sobre controles técnicos se realizarán de manera **semestral**, mientras que la auditoría integral del SGSI (abarcando políticas, procesos y cumplimiento normativo) se ejecutará con frecuencia **anual**.
- **Independencia del Auditor:** Para garantizar la objetividad y evitar conflictos de interés, el personal asignado para realizar las auditorías internas **no debe tener responsabilidades operativas sobre el área o control que está auditando**. (Por ejemplo, un administrador de red no podrá auditar las reglas del firewall, ni un desarrollador auditará los repositorios Git).
- **Metodología General:** Las evaluaciones se llevarán a cabo mediante un enfoque integral que incluirá:
 - Revisión analítica de bitácoras (logs) de acceso lógico en plataformas críticas y revisión de alertas de intentos fallidos.
 - Entrevistas con los Propietarios de Activos para validar la correcta clasificación y asignación de permisos bajo el principio de mínimo privilegio.

- Pruebas técnicas y operativas, incluyendo simulacros de incidentes y comprobación de seguridad física (ej. intentos controlados de acceso a la sala de servidores utilizando biometría/tarjetas RFID).

4. REVISIÓN POR LA DIRECCIÓN

La gobernanza de la seguridad de la información requiere la participación activa de la alta gerencia. Los resultados consolidados de los KPIs, los informes del CSIRT y los hallazgos del Programa de Auditoría Interna serán presentados formalmente a la **Dirección General** al menos una vez al año, o de manera extraordinaria ante incidentes críticos.

El propósito de esta revisión es proveer a la Dirección de los datos necesarios para:

- Evaluar si el SGSI sigue alineado con los objetivos estratégicos de NovaTech Solutions.
- Tomar decisiones informadas para el ajuste de procesos o políticas.
- Aprobar o reasignar el presupuesto necesario para la mitigación de nuevos riesgos descubiertos o la adquisición de herramientas tecnológicas de seguridad.
- Fomentar el ciclo de Mejora Continua (Act), ordenando acciones correctivas inmediatas ante cualquier no conformidad detectada.